FREE · OPEN SOURCE · MIT · VERSION 2.0

safe-ai-coding
Quick Start Guide

Make your AI coding agent safe in two minutes. It asks before anything risky, catches the mistakes AI makes, and reviews every change like a careful teammate.



1. Install

Two commands in Claude Code, or one git command.

2. Work as usual

Ask for features and fixes in your own words. The skill guides the agent.

3. Stay in control

Risky steps wait for your "yes", with the possible harm explained first.

For developers everywhere

By Sami Hussain · x8code.com

1 What is safe-ai-coding?

safe-ai-coding is a free skill for Claude Code that makes AI coding agents safer. When the agent writes or reviews code, the skill makes it follow the habits of a careful senior developer, and stop to ask before doing anything that could cause damage.

45%
of AI-generated code samples failed security tests in a 2025 study
Veracode, July 2025

205,474
made-up package names produced by code models; attackers can register them
USENIX Security 2025

#1
Prompt injection is the top risk for LLM applications
OWASP, 2025

What you get

It asks before harm

Installs, database changes, deleting files, git pushes, secrets, sending data out: the agent stops, explains what could go wrong and whether it can be undone, and waits for your yes.

It catches AI mistakes

Methods and files that do not exist, "rest of the code unchanged" placeholders, SQL injection, leaked keys, risky migrations, weakened tests, and more than 50 other checks.

It reviews like a team

Every change is read twice: once for the ways AI code fails, once as the teammate who will maintain it. You get a clear verdict: Ready, Ready with notes, or Not ready.

It protects the agent itself

Before work starts, it scans a repository for hidden instructions, malicious git settings, dangerous install scripts and links to your private keys.

Safe by design

Everything runs on your machine. It never runs code from the repository it checks, and it sends nothing anywhere.

2 Install in two minutes

Option 1: Claude Code plugin (recommended)

Type these two lines inside Claude Code:

```
/plugin marketplace add sami-hussain-dev/safe-ai-coding
/plugin install safe-ai-coding@safe-ai-coding
```

Option 2: one git command

```
# macOS, Linux or Git Bash
git clone --depth 1 https://github.com/sami-hussain-dev/safe-ai-coding.git ~/.claude/skills/safe-ai-coding

# Windows PowerShell
git clone --depth 1 https://github.com/sami-hussain-dev/safe-ai-coding.git "$env:USERPROFILE\.claude\skills\safe-ai-coding"
```

Start a new Claude Code session (or run `/reload-plugins`). That is all. Pick one option, not both.

To	Plugin	Git
Update	`/plugin` → Marketplaces → safe-ai-coding → Update	`git -C ~/.claude/skills/safe-ai-coding pull`
Remove	`/plugin uninstall safe-ai-coding@safe-ai-coding`	Delete the folder

Check it works (optional, 30 seconds)

Type this inside Claude Code:

```
/safe-ai-coding:safe-ai-coding self-test
# Result: 95 passed, 0 failed
```

You need	Notes
Claude Code	Terminal, VS Code, JetBrains or desktop app
`git` and `bash`	On Windows, install Git for Windows (it includes Git Bash and Perl)
Chrome or Edge	Optional, only for PDF reports

3 Use it every day

You do not need to learn anything new. Ask Claude Code for the work in your own words; the skill loads by itself. These commands are there when you want a specific mode.

When	Type	You get
You just cloned a project	`/safe-ai-coding:safe-ai-coding scan`	A list of anything that could trick or attack the agent
You want a feature or a fix	Just ask, or `/safe-ai-coding:safe-ai-coding build <task>`	Careful code in your project's style, then an automatic review
Before you merge	`/safe-ai-coding:safe-ai-coding review main`	Findings table and a clear verdict
You need a document	"Give me a PDF report of this work"	A polished PDF: what was wrong, what was fixed, the proof
After installing or updating	`/safe-ai-coding:safe-ai-coding self-test`	Proof that every check works

What a permission request looks like

The agent stops and asks

```
PERMISSION NEEDED: install the package "pdf-parse"
What:          npm install pdf-parse@1.1.1   (this project, branch feature/upload)
Why:           the upload screen must read text from PDF files
Possible harm: - the package and its dependencies run install scripts on this machine
               - a look-alike name could be malware; I checked the exact name on npmjs.com
Reversible?:   yes: npm uninstall pdf-parse, and revert package.json and the lock file
Safer option:  use the PDF library already in the project (pdfjs-dist)
Reply yes to run exactly this, no to skip it, or choose the safer option.
```

What a review finding looks like

```
HIGH  app/Http/Controllers/OrderController.php:42  SQL built from request input: SQL injection; use
bound parameters
      > $rows = DB::select("SELECT * FROM orders WHERE id = $request->id");
WARN  app/Http/Controllers/OrderController.php:58  Billing::refundAll() not found in
app/Services/Billing.php: hallucinated or misspelled method
```

4 Questions and answers

What is the best way to make Claude Code safer?

Install a guardrail skill such as safe-ai-coding, and add permission rules in `.claude/settings.json` for the commands you never want run without asking. The skill handles judgement; the settings give hard limits.

Does safe-ai-coding stop AI hallucinations in code?

It catches many of them. The review checks that classes, static methods, views, routes, config files and imports used in new code really exist in your repository, and the build steps tell the agent to confirm every symbol before using it.

How does it protect against prompt injection?

It treats everything the agent reads as data, never as orders. It scans instruction files (CLAUDE.md, AGENTS.md, Cursor and Copilot rules), including inside dependencies, for hidden or malicious instructions and invisible unicode, and reports them to you.

Which languages and frameworks does it support?

Any. The checks cover PHP and Laravel, JavaScript and TypeScript, Python, Java, C#, Go and Ruby, and you can add your own project rules.

Does it send my code anywhere?

No. All checks run locally, and it never executes code from the repository it scans.

Is it free?

Yes. It is open source under the MIT license.

Does it replace code review?

No. It makes AI-written code much safer and reviews it carefully, but a person should still approve every change.

Where is the full documentation?

The complete guide (English and Roman Urdu) is in the `docs/` folder of the repository.

About the author

Sami Hussain · x8code.com · samihussain9t9@gmail.com

Project home, updates and issues: github.com/sami-hussain-dev/safe-ai-coding · MIT License

---

safe-ai-coding 2.0 · Sources: Veracode GenAI Code Security Report (30 Jul 2025); Spracklen et al., USENIX Security 2025, arxiv.org/abs/2406.10279; OWASP LLM01:2025 Prompt Injection. The skill reduces risk; it does not prove code is safe.